

Security & Authorization Design

Web-Based Vehicle Auction Platform

1. Purpose

This section describes the **security mechanisms** used to protect system resources and enforce **authorization rules**. The design ensures that only authenticated and authorized users can perform restricted actions such as bidding and administrative operations.

2. Authentication Mechanism

- Users are authenticated using **credential-based authentication** (email and password).
- Upon successful login, the system establishes an authenticated session or issues a secure token.
- Passwords are stored in the database as **hashed values**, ensuring credential confidentiality.

3. Authorization Model

The system uses **Role-Based Access Control (RBAC)** to restrict access to functionality based on user roles.

Defined Roles

- **Guest:** Unauthenticated users
- **Registered User:** Authenticated but not verified
- **Verified User:** Authenticated and admin-verified users
- **Admin:** System administrator

4. Access Control Rules

Action	Required Role
View vehicles	Guest
View auction details	Guest
Place bid	Verified User
Create auction	Admin
Verify user	Admin
View bid history	Admin

5. Verification Enforcement

- User verification is performed by an **administrator**.
- The `is_verified` attribute in the User entity determines bidding eligibility.
- Bid placement requests are rejected if the user is not verified, even if authenticated.

6. Security Enforcement Layer

- Authentication and authorization checks are enforced at the **backend application layer**.
- Controllers validate access rights before delegating requests to service classes.
- Business rules related to security are enforced consistently across all protected endpoints.

7. Error Handling and Response

- Unauthorized access attempts result in appropriate HTTP status codes:
 - 401 Unauthorized for unauthenticated users
 - 403 Forbidden for insufficient permissions
- Error responses do not expose sensitive system details.